CYBER & NETWORK SECURITY

When the Wrong Door Stays Unlocked

Five real cyber attacks on five real companies

Report on Different Cyber Attacks on Different Companies

BigBasket · C-Edge Technologies · Change Healthcare · Twitter · Twitch

STUDENT INFORMATION:

Name	Chauhan Yuvraj
Enrollment	241105060017
Class	B
Batch	B11

REPORT OVERVIEW:

This report looks at five cyber attacks that hit real organisations: two in India and three in the United States. For each one it explains how the attackers got in, what the damage was, how the company responded, and which basic security habits might have made the incident smaller, or stopped it altogether.

KEY FOCUS:

Credential theft · Supplier compromise · Ransomware · Voice phishing · Cloud misconfiguration

BEFORE YOU START

How to read this report

Most security reports are long lists of famous hacks. This one is deliberately smaller. It follows five incidents, and each one shows a different kind of weak spot: a stolen user database, a supplier's servers, a login with no second step, a phone call to staff, and a server setting that was wrong. Two of the cases are Indian and three are not. Every case gets the same three pages, so you can compare them side by side.

A NOTE ON THE CLIPPINGS

The newspaper pages are made for this report. They are styled like clippings so that each incident feels like news, but they are not scans of real newspapers, and the wording is a summary written for this file. Dates, amounts and company actions come from company statements, regulatory and court documents and press reports. Where public accounts disagree, or where only one side has spoken, the text says so.

What sits where

No.	Section	Page
1	Five ways in: the attack types behind these cases	p. 3
2	Case 1 · BigBasket, 2020 (India)	p. 4
3	Case 2 · C-Edge Technologies, 2024 (India)	p. 7
4	Case 3 · Change Healthcare, 2024 (United States)	p. 10
5	Case 4 · Twitter, 2020 (United States)	p. 13
6	Case 5 · Twitch, 2021 (United States)	p. 16
7	What the five cases have in common	p. 19

One habit while you read

For every case, look for the quiet gap: the stretch of time between the attackers getting in and anyone noticing. In some of these stories it was hours, in others weeks. The expensive part of an attack is rarely the first break-in. It is the long period afterwards when an odd login or a big data transfer was happening and nobody owned the alarm.

Five ways in

The five cases look different on the surface, but each one starts from a different kind of weak point. Here are the five labels used in this report.

Attack type	What it means	Case in this report
Credential and data theft	The attacker copies stored user data, such as emails and password hashes, then sells or leaks it.	BigBasket
Supplier (third-party) compromise	The target is not hit directly. A company that holds its data or runs its systems is.	C-Edge Technologies
Ransomware	Malware locks a company's systems and demands payment. Data is often stolen first, so there are two threats instead of one.	Change Healthcare
Voice phishing (vishing)	The attacker phones staff or the IT help desk with a believable story and talks their way in.	Twitter
Cloud misconfiguration	A setting is wrong, such as a server rule or a permission that is too wide, and an outsider finds it.	Twitch

Why labels only go so far

Real incidents blur the categories. A vishing call can lead to account takeover and a public scam, as it did at Twitter. A supplier breach can start with a bad setting at the supplier's own partner, as at C-Edge. A stolen password with no second step can let an attacker sit inside a network for days, as at Change Healthcare. The more useful question is practical: what did the attacker ask a person or a system to trust, and why did nothing stop it?

How an attack usually runs

1. Get in
A stolen password, a supplier, a call or a bad setting.

2. Look around
Use the access to find tools, data or admin rights.

3. Take or lock
Copy data, encrypt systems or both.

4. Get noticed
A ransom note, a news story or a stranger's tip.

WORTH REMEMBERING

None of these organisations was short of security tools. Change Healthcare belonged to one of the largest health companies in the world, Twitter had a security team and two-factor login, and Twitch ran a large engineering operation. What failed was a small, ordinary thing next to the tools: a portal with no second step, a caller who was never checked, a setting that was never reviewed.

Case 1 · BigBasket, November 2020

CASE 1 · INDIA

The Daily Ledger

SPECIAL REPORT · ILLUSTRATIVE EDITION

E-COMMERCE · INDIA

BIGBASKET DATA OF 20 MILLION USERS REPORTEDLY ON SALE ONLINE

Security firm finds a 15 GB database listed for about $40,000; company files police complaint

Bengaluru, November 8, 2020. Online grocer BigBasket said it is evaluating a potential data breach after US-based security firm Cyble reported that a database of close to 20 million users was being sold on a cybercrime market. Cyble said the records include names, email addresses, password hashes, phone numbers, home addresses, dates of birth, locations and login IP addresses.

The company said it has filed a complaint with the cyber crime police in Bengaluru and that it is confident the financial data of its users is secure. Cyble said it told BigBasket's management on 1 November, six days before its report went public.

20M

user records reported on sale

Staged clipping made for this report. Figures follow Cyble's report and press coverage from November 2020.

READ THE FULL ACCOUNT ON THE NEXT PAGE

At a glance

ORGANISATION	BigBasket, online grocery and delivery platform, Bengaluru, India
WHEN	Breach dated 14 Oct 2020 by Cyble (some reports say 30 Oct); found 30 Oct; BigBasket told 1 Nov; made public 7 Nov 2020
WHAT WAS TAKEN	About 20 million user records: names, emails, password hashes, phone numbers, addresses, dates of birth, location and login IP addresses
WHAT WAS NOT	BigBasket said it was confident that users' financial data was secure
WHO NOTICED	Cyble, a US security firm, during routine dark-web monitoring. The database was listed at over $40,000 (about Rs 30 lakh)
OUTCOME	Police complaint filed in Bengaluru; company evaluated the breach; no detailed technical write-up was published

Case 1 · BigBasket

Twenty million customer records, a 15 GB file and a price tag of about forty thousand dollars. The company learned about it from an outside security firm.

What happened

In early November 2020 Cyble, a US cyber-intelligence firm, said that during routine dark-web monitoring it had found a BigBasket database for sale on a cybercrime market. The file was an SQL dump of about 15 GB, with a table named member_member and close to 20 million user records. Cyble said it detected the listing on 30 October, checked it on 31 October by matching the leaked data against real BigBasket users, and told BigBasket's management on 1 November. It published its findings on 7 November. BigBasket then said it was evaluating a potential breach and had filed a police complaint in Bengaluru.

Why this kind of data still matters

Passwords were stored as hashes, and BigBasket said financial data was safe, which limited the damage. But a name, a phone number, a home address and a date of birth are not things a person can reset. Together they make a ready-made list for phishing calls, fake delivery messages and identity guessing. Cyble also noted entries that appeared to be hashed one-time passwords, a reminder that even login helpers need careful storage.

How they got in

BigBasket has not published how the database was copied, so the method is not public. Cyble's report gave 14 October as the date of the alleged breach, while some press accounts say 30 October, which is the day Cyble found the listing. Until the company explains, both the date and the method are best treated as claims.

What it cost

No money was reported stolen and the company said payment data was safe, so the damage is mostly about trust and risk. According to press reports at the time, BigBasket had not yet written to users directly days after the story broke, so many customers learned about it from the news.

How they responded

BigBasket said it was evaluating the extent of the breach, filed a complaint with the Bengaluru cyber crime police and said financial data was secure. Unlike some other cases in this report, there was no detailed public account of what went wrong or what changed afterwards.

How the path ran

1. Database copied
User records are taken from BigBasket's systems, reportedly around 14 October.

2. Listed for sale
A seller offers the file on a cybercrime market for over $40,000.

3. Spotted by Cyble
Cyble finds, checks and reports it to BigBasket on 1 November.

4. Public and police
The report goes public on 7 November; a police complaint follows.

BigBasket, November 2020, step by step

Timeline

When	What happened
14 Oct 2020	Alleged date of the breach, according to Cyble. BigBasket has not confirmed the date or the method.
30–31 Oct	Cyble spots the listing, then checks it against real BigBasket user details.
1 Nov	Cyble tells BigBasket's management.
7 Nov	Cyble publishes its findings. Press reports say about 20 million users are affected.
8 Nov	BigBasket says it is evaluating the breach, has filed a police complaint, and that financial data is secure.

Where it could have been caught

Slow, salted hashing
Deliberately slow hashes such as bcrypt or Argon2 make each guess costly, and salting stops one cracked password from helping with another.

An alarm on big reads
A 15 GB export of a user table should trip an alert on the way out, not be found later on a market.

Hold less personal data
Dates of birth, addresses and old login data that nobody needs any more are risk with no benefit.

Tell customers first
A short, honest notice to users, ahead of the news cycle, lets them reset passwords and watch for scams.

TRY THIS YOURSELF

Be careful with unexpected calls or messages that quote your name, address or a past order. Check inside the official app, and never share an OTP with a caller, however well they seem to know you.

Case 2 · C-Edge Technologies, July 2024

CASE 2 · INDIA

The Daily Ledger

SPECIAL REPORT · ILLUSTRATIVE EDITION

BANKING · INDIA

RANSOMWARE ON BANKING TECH PROVIDER HITS PAYMENTS AT ABOUT 300 SMALL BANKS

NPCI cuts C-Edge off from retail payment systems; connectivity restored within days

Mumbai, July 31, 2024. The National Payments Corporation of India said on Wednesday that C-Edge Technologies, a technology provider that serves mostly cooperative and regional rural banks, may have been hit by a ransomware attack on a few of its systems. To limit the impact on the wider payment ecosystem, NPCI temporarily cut C-Edge off from the retail payment systems it runs. Customers of the banks served by C-Edge could not use those systems while the isolation lasted.

Press reports put the number of banks at nearly 300 and said customers had been seeing problems with UPI and ATM withdrawals since about 29 July. NPCI said restoration was under way and a security review was in progress.

~300

small banks cut off from payments

Staged clipping made for this report. Figures follow NPCI's statement of 31 July 2024 and press reports.

READ THE FULL ACCOUNT ON THE NEXT PAGE

At a glance

ORGANISATION	C-Edge Technologies, a joint venture of TCS and State Bank of India that runs software for small cooperative and regional rural banks
WHEN	Problems reported from about 29 July 2024; NPCI statement on 31 July; connectivity restored on 1 August
HOW MANY	Nearly 300 small banks, according to press reports citing regulatory officials
THE WEAK POINT	A supplier's supplier. Reports say the attack began at Brontoo Technology Solutions, a C-Edge partner, through a misconfigured Jenkins server
ATTRIBUTION	Security firm CloudSEK linked the attack to the RansomEXX group. That is a vendor finding, not a court ruling
OUTCOME	NPCI isolated C-Edge; the affected systems were isolated and an independent audit ran scans before connectivity returned

Case 2 · C-Edge Technologies

The banks themselves were not hacked. A company that runs their software was, and nearly 300 of them lost payments for several days.

What happened

C-Edge Technologies is a joint venture of Tata Consultancy Services and State Bank of India. It provides core banking software and related services to small banks, mostly cooperative and regional rural banks, which outsource their technology rather than run it themselves. In the last week of July 2024 customers of many of those banks found that UPI payments and ATM withdrawals were not working. Reports said the problems began around 29 July, and that 17 district cooperative banks in Gujarat were among those affected. On 31 July NPCI, which runs the national retail payment systems, said C-Edge may have been hit by ransomware and cut it off from those systems as a precaution.

Whose problem was it?

Customers trusted their bank. The bank trusted C-Edge. According to later analysis, C-Edge's exposure came through one of its own partners. A small bank can do everything right and still be offline because of a company two steps away.

How they got in

C-Edge made few public statements. CloudSEK, a security firm, reported that the RansomEXX group first hit Brontoo Technology Solutions, a C-Edge partner, through a misconfigured Jenkins server, a tool developers use to build and deploy software. Other reports tied the case to a known Jenkins flaw, CVE-2024-23897, which had been fixed in January 2024. The accounts differ on the exact cause, so it is best read as reported, not confirmed. Either way the lesson is the same: a build server was reachable and nobody had closed it.

What it cost

No ransom and no customer losses were reported. The cost was days of broken payments for people and shops that depend on small local banks, many of them in rural and semi-urban areas, plus the work of cutting off and then re-checking a core part of the payment system.

How they responded

NPCI's quick decision to isolate C-Edge is the part of this case that held up best. It kept a problem at one supplier from spreading across the national payment system. A forensic audit and scans followed, and NPCI restored connectivity on 1 August. Early accounts from bank staff described the problem as a technical fault, which left customers guessing until the official notice.

How the path ran

1. Partner server exposed
A misconfigured Jenkins server at Brontoo, a C-Edge partner, is reportedly the way in.

2. C-Edge systems hit
RansomEXX ransomware affects a few C-Edge systems from about 29 July.

3. NPCI cuts it off
On 31 July C-Edge is isolated from the retail payment systems.

4. Back online
After a security review, connectivity returns on 1 August.

C-Edge Technologies, July 2024, step by step

Timeline

When	What happened
Late Jul 2024	Attackers reach a Brontoo server and then C-Edge systems. A KPMG threat note says NPCI was told on 26 July.
About 29 Jul	Customers of many small banks see UPI and ATM problems.
31 Jul	NPCI says C-Edge may have been hit by ransomware and isolates it from retail payment systems.
1 Aug	NPCI restores connectivity after a security review. CloudSEK publishes its report naming RansomEXX and the Jenkins server.
Early Aug	Bank services return to normal. The wider payment system is reported to be unaffected.

Where it could have been caught

Map your suppliers' suppliers
Ask which partners touch your systems and what they run. The weak point here sat two steps from the banks.

Check build and admin servers
Tools such as Jenkins should not be open to the internet, and known flaws should be patched fast.

Be able to cut off fast
NPCI's isolation limited the spread. Every shared system needs a pre-agreed way to disconnect a bad link.

Say what happened
A plain, early notice beats a vague "technical fault". Customers need to know what to do and what to avoid.

TRY THIS YOURSELF

When a bank app or UPI is down, do not search for a "helpline" and call the first number you find. Scammers use outages. Use the number printed on your card or on the bank's own website.

Case 3 · Change Healthcare, February 2024

CASE 3 · OUTSIDE INDIA

The Daily Ledger

SPECIAL REPORT · ILLUSTRATIVE EDITION

HEALTHCARE · UNITED STATES

CHANGE HEALTHCARE: 192.7 MILLION PEOPLE AFFECTED BY RANSOMWARE ATTACK

Remote-access login with no multi-factor step let ALPHV in; pharmacies and hospitals went weeks without normal payments

Minnetonka, Minn., July 31, 2025. Change Healthcare, a UnitedHealth Group company, has told the US Department of Health and Human Services that about 192.7 million people were affected by the ransomware attack it suffered in February 2024, making it the largest healthcare data breach on record. The attack, claimed by the ALPHV (BlackCat) group, disrupted claims, prescription and payment systems across the country for weeks.

UnitedHealth's chief executive told Congress in May 2024 that the attackers got in with stolen credentials on a Citrix remote-access portal that had no multi-factor authentication, and that the company paid a $22 million ransom.

192.7M

people affected, per notice to HHS

Staged clipping made for this report. Figures follow UnitedHealth's testimony to Congress, its SEC filings and notices to HHS.

READ THE FULL ACCOUNT ON THE NEXT PAGE

At a glance

ORGANISATION	Change Healthcare, a UnitedHealth Group (Optum) company that processes healthcare claims and payments, United States
WHEN	First access 12 Feb 2024; data copied about 17–20 Feb; ransomware deployed 21 Feb 2024
ENTRY POINT	Stolen credentials used on a Citrix remote-access portal that had no multi-factor authentication
GROUP	ALPHV (BlackCat), a ransomware-as-a-service operation
RANSOM	About 22 million US dollars in Bitcoin, paid by UnitedHealth and later confirmed by its CEO
DATA	About 192.7 million people (HHS notice, July 2025): health, insurance and billing information, and for some people, Social Security numbers
COST	About 872 million dollars in the first quarter of 2024 alone, per UnitedHealth, with more in later quarters

Case 3 · Change Healthcare

One remote login with no second step, and one of the busiest payment hubs in US healthcare went dark.

What happened

On 21 February 2024 UnitedHealth detected ransomware on Change Healthcare's network and cut the company's systems off from its customers. Change is a clearinghouse: hospitals, doctors and pharmacies send it insurance claims, and it passes back approvals and payments. UnitedHealth's chief executive, Andrew Witty, said it touches about one in three US patient records. With it down, pharmacies could not easily check coverage and many providers stopped being paid on time.

How they got in

According to Witty's written testimony to Congress, criminals used compromised credentials to log in to a Change Healthcare Citrix portal on 12 February. The portal was used for remote desktop access and had no multi-factor authentication. Once inside, the attackers moved through the network and copied data. Ransomware was deployed nine days later. How the credentials were stolen has not been confirmed in public, though one security firm pointed to infostealer malware on an employee device. UnitedHealth had bought Change in 2022, and Witty said the company was still bringing its systems up to UnitedHealth's standards, including adding MFA.

The ransom

UnitedHealth paid 22 million dollars in Bitcoin to ALPHV, around the start of March according to reports, and Witty confirmed it under oath. It did not end the problem. ALPHV soon vanished in what looked like an exit scam, and a second group, RansomHub, claimed to hold the stolen data and demanded more money. Paying for a promise to delete data turned out to be worth very little.

What it cost

UnitedHealth reported about 872 million dollars of cost in the first quarter of 2024, with more later, and said it advanced billions of dollars to providers to keep them running. The count of affected people grew as investigators worked: about 100 million in October 2024, about 190 million in January 2025 and 192.7 million in July 2025.

How they responded

UnitedHealth isolated Change's systems the day it detected the attack, filed an SEC report the next day and rebuilt services in stages over the following weeks. Witty told Congress the company had since made MFA mandatory. The slow part of this story is the notification count, which took about seventeen months to settle.

How the path ran

1. Citrix login
A stolen password with no MFA is used on 12 February.

2. Nine quiet days
Attackers move inside and copy data, about 17–20 February.

3. Ransomware
Systems are encrypted on 21 February.

4. Network cut off
Change is isolated; claims and payments stop.

Change Healthcare, February 2024, step by step

Timeline

When	What happened
12 Feb 2024	Attackers log in to the Citrix portal with compromised credentials. There is no MFA.
17–20 Feb	Data is copied out of the network.
21 Feb	ALPHV ransomware is deployed. UnitedHealth detects it and isolates Change's systems.
22 Feb	UnitedHealth files a report with the SEC.
Early Mar 2024	A 22 million dollar Bitcoin payment is reported. The CEO confirms it under oath on 1 May.
22 Oct 2024	Change tells HHS that about 100 million notices have gone out.
24 Jan 2025	The estimate rises to about 190 million people.
31 Jul 2025	Change tells HHS that about 192.7 million people were affected.

Where it could have been caught

MFA on every remote door
A password alone should never be enough to open a remote-access portal.

Fix acquired systems first
Buying a company means inheriting its weak spots. MFA and patching should be checked before systems are connected.

Watch the quiet days
Nine days of movement and bulk copying should set off an alarm long before a ransom note appears.

Practise being down
A hub that many others depend on needs an offline fallback for claims and payments, rehearsed in advance.

TRY THIS YOURSELF

Turn on two-step login for your email, bank and any work or school remote login today. An authenticator app or a security key is stronger than a text message.

Case 4 · Twitter, July 2020

CASE 4 · OUTSIDE INDIA

The Daily Ledger

SPECIAL REPORT · ILLUSTRATIVE EDITION

SOCIAL MEDIA · UNITED STATES

TWITTER ACCOUNTS OF OBAMA, GATES AND MUSK HIJACKED IN BITCOIN SCAM

Company says staff were targeted in a coordinated social-engineering attack; internal tools used to take over accounts

San Francisco, July 18, 2020. Twitter said attackers targeted 130 accounts after a coordinated social-engineering attack on its employees on Wednesday. Messages promising to double any Bitcoin sent to an address were posted from 45 of them, among them the accounts of Barack Obama, Joe Biden, Elon Musk, Bill Gates and Apple. The company said the attackers used what they learned from employees to reach internal systems and tools, then took control of the accounts.

Twitter temporarily stopped many verified accounts from tweeting, locked accounts it believed were affected and said it was working with law enforcement. Press reports put the Bitcoin sent to the scam addresses at about 120,000 dollars.

130

accounts targeted by the attackers

Staged clipping made for this report. Figures follow Twitter's updates of July 2020 and press reports.

READ THE FULL ACCOUNT ON THE NEXT PAGE

At a glance

ORGANISATION	Twitter, Inc., San Francisco, United States (now called X)
WHEN	15 July 2020; arrests announced 31 July 2020
HOW (REPORTED)	Phone calls to employees by people posing as IT staff, leading to stolen logins and access to an internal account tool
SCALE	130 accounts targeted; tweets sent from 45; direct messages opened for 36; account data downloaded for 8 (Twitter's figures)
LOSS	About 120,000 dollars in Bitcoin sent by people who believed the tweets (press reports)
WHO	Graham Ivan Clark, then 17, of Tampa, was arrested in Florida; two others were charged by US federal prosecutors
OUTCOME	Clark pleaded guilty in 2021 and accepted a three-year prison term; Twitter limited access to its internal tools

Case 4 · Twitter

A few phone calls to employees were enough to hand strangers the account-takeover tool, and some of the most followed accounts in the world began asking for Bitcoin.

What happened

On the afternoon of 15 July 2020 tweets began appearing on the accounts of politicians, business leaders and companies, offering to double any Bitcoin sent to a given address. Because the messages came from verified accounts with millions of followers, many people believed them. Twitter reacted by stopping verified accounts from tweeting for several hours and locking accounts it thought were affected. The scam itself was crude. The way in was not.

How they got in

Twitter described a coordinated social-engineering attack. According to its updates and to a later report by New York's financial regulator, the attackers phoned employees, many of them working from home during the pandemic, and posed as colleagues from Twitter's IT team. They steered the employees to a fake login page and collected their credentials. Twitter said the attackers got past its two-factor protection as well, and then reached an internal support tool that could change an account's email address and reset its password. For some accounts that was all they needed.

The people behind it

Florida prosecutors charged Graham Ivan Clark, a 17-year-old from Tampa, who was arrested on 31 July 2020 and later pleaded guilty. The US Justice Department charged two others, Mason Sheppard in the United Kingdom and Nima Fazeli in Florida, for their roles in the scheme.

What it cost

Victims sent about 120,000 dollars in Bitcoin. The wider harm was trust. Twitter said the attackers had opened the direct messages of 36 accounts, and for a short time nobody could be sure what else they could reach. The New York regulator's report in October 2020 found that weak controls on internal tools and gaps in staff training had made the attack easier, and urged stronger measures such as hardware security keys.

How they responded

Twitter locked affected accounts, cut access to internal tools while it investigated, brought in the FBI and published regular updates. Arrests came within about two weeks. Twitter said it had limited access to its internal tools and improved its detection of misuse.

How the path ran

1. Call employees
Callers pose as Twitter IT staff and steer workers to a fake login page.

2. Logins captured
Passwords and codes are collected, including past two-factor checks.

3. Internal tool opened
A support tool lets the attackers change emails and reset passwords.

4. Accounts taken over
Hijacked accounts post a Bitcoin scam on 15 July.

Twitter, July 2020, step by step

Timeline

When	What happened
15 Jul 2020	Afternoon: attackers phone employees and capture logins. Evening (US time): scam tweets start and Twitter blocks verified accounts from tweeting.
18 Jul	Twitter says 130 accounts were targeted and tweets were sent from 45.
22 Jul	Twitter adds that direct messages were opened for 36 accounts and data was downloaded for 8.
31 Jul	Clark is arrested in Tampa. Federal charges against two others are announced.
Oct 2020	New York’s financial regulator publishes its investigation report.
Mar 2021	Clark pleads guilty and receives a three-year prison term.

Where it could have been caught

Security keys, not codes
Hardware keys are far harder to trick than a code that someone reads out or types into a fake page.

Few hands on the tool
Only a small, named group should be able to change an account’s email or password, and every use should be logged.

Two-person rule
Changing a high-profile account should need a second person’s approval.

Train for the call
Test staff with realistic phone pretexts and give them an easy, safe way to say no.

TRY THIS YOURSELF

Never type a password or code into a page you reached from a call or a message. Close it, then open the company’s login page yourself, or call back on a number you already have.

Case 5 · Twitch, October 2021

CASE 5 · OUTSIDE INDIA

The Daily Ledger

SPECIAL REPORT · ILLUSTRATIVE EDITION

STREAMING · UNITED STATES

TWITCH CONFIRMS BREACH AFTER 125 GB OF INTERNAL DATA POSTED ONLINE

Source code and streamer payout figures leak; stream keys reset; no passwords or full card numbers exposed, company says

San Francisco, October 6, 2021. Twitch confirmed on Wednesday that a breach had taken place after an anonymous user on the message board 4chan shared a link to what was described as 125 GB of the company's internal data. The leak was reported to include Twitch's source code, internal tools and earnings figures for streamers. The company said it was investigating.

Twitch later said the cause was an error in a server configuration change, and that it had no sign that login credentials or full credit card numbers were exposed. The company reset all stream keys as a precaution.

125 GB

of internal data posted online

Staged clipping made for this report. Figures follow Twitch's statements of October 2021 and press reports.

READ THE FULL ACCOUNT ON THE NEXT PAGE

At a glance

ORGANISATION	Twitch Interactive, a live-streaming platform owned by Amazon, San Francisco, United States
WHEN	Leak posted on 6 Oct 2021; the date of the intrusion has not been made public
WHAT WAS TAKEN	About 125 GB (reported): source code, internal tools, and payout reports for top streamers covering roughly 2019 to 2021
WHAT WAS NOT	Twitch said it had no sign that login credentials or full credit card numbers were exposed
THE CAUSE	An error in a server configuration change, according to Twitch
WHO	An anonymous poster on 4chan; not identified in public
OUTCOME	All stream keys reset; users urged to turn on two-factor login; no regulatory penalty has been widely reported

Case 5 · Twitch

Twitch said no passwords were exposed. A server setting still let someone take its source code and its creators' payout figures.

What happened

On 6 October 2021 an anonymous user on 4chan posted a link to a torrent described as 125 GB of Twitch data. The files were reported to include Twitch's source code, internal tools, an unreleased game-store project and payout reports for top streamers going back to 2019. The poster said the aim was to cause more disruption and competition in video streaming. Twitch confirmed the same day that a breach had taken place and said it was investigating.

Why the data mattered

Source code shows how a service is built, which can help others find weak spots. The payout reports made the earnings of creators public, which was awkward for them and for Twitch. Twitch said the leak did not include login credentials or full credit card numbers, which limited the harm to its users but not to the company.

How they got in

Twitch's own explanation, given on 15 October, was short: an error in a server configuration change allowed an outside party to get access. It has not said how the data was found, when the access began or how it was copied, so those details are not public. What the explanation does show is how a simple setting can matter. A server that should have been closed to the internet, or an access rule left too wide, can let an outsider reach data without breaking a single password.

What it cost

No money was reported stolen from customers, and no regulatory penalty over the leak has been widely reported. The costs were in trust and competition: Twitch had to reset every stream key, creators' earnings were exposed to the world, and the source code could not be taken back. A leak of code is permanent in a way that a leaked password is not, because a password can be changed.

How they responded

Twitch confirmed the breach on the day, reset all stream keys as a precaution, urged users to turn on two-factor login and published its explanation nine days later. The quick confirmation and the key reset are the parts of this case that held up best.

How the path ran

1. Setting changed
A server configuration change leaves a system open to outsiders. The date is not public.

2. Data copied
About 125 GB, reportedly including source code and payout reports.

3. Posted publicly
A torrent link appears on 4chan on 6 October.

4. Confirmed and fixed
Twitch confirms the same day, resets stream keys and later explains the cause.

Twitch, October 2021, step by step

Timeline

When	What happened
Date not public	A configuration change gives an outsider access, and data is copied.
6 Oct 2021	The torrent is posted. Twitch confirms a breach the same day.
6 Oct	Twitch resets all stream keys and urges users to turn on two-factor login.
15 Oct	Twitch says the cause was an error in a server configuration change and that it saw no sign that passwords or full card numbers were exposed.

Where it could have been caught

Review every config change
A change that opens a server should be reviewed by a second person and checked by an automated scanner.

Keep the crown jewels apart
Source code and finance data should sit behind separate, narrow access, not behind one setting.

Watch the exits
125 GB leaving the company should raise an alarm within minutes, with a named owner.

Be ready to rotate
Twitch’s fast key reset shows the value of being able to change secrets in bulk, quickly.

TRY THIS YOURSELF

If you run any server or cloud storage, check today what is open to the whole internet. For every open door, ask whether it is meant to be.

What the five cases have in common

None of these companies was run by careless people having a cartoonishly bad day. They were busy, and each attacker found the one door that was easy to push. The table below sets the five side by side.

Case	How they got in	What limited the damage	What was missing
BigBasket, 2020	Database copied; method not published	Hashed passwords; company said financial data was safe	Alerts on bulk data reads; early notice to users
C-Edge, 2024	A partner's misconfigured Jenkins server	NPCI's fast isolation of C-Edge	Checks on suppliers' servers; patching
Change Healthcare, 2024	Stolen Citrix login, no MFA	Systems isolated the day it was detected	MFA; an alarm on nine quiet days
Twitter, 2020	Phone calls to employees	Accounts locked; arrests within two weeks	Security keys; fewer people on the admin tool
Twitch, 2021	Error in a server configuration change	Passwords not exposed; fast stream-key reset	Config review; exit monitoring

The quiet gap, case by case

Case	Quiet gap	Measured between
BigBasket	About 3 weeks (alleged)	From the alleged breach on 14 Oct 2020 to Cyble's public report on 7 Nov. Some reports give 30 Oct as the breach date.
C-Edge	A few days (reported)	From NPCI being told (reportedly 26 Jul) to its public statement on 31 Jul 2024.
Change Healthcare	9 days	First access on 12 Feb to the ransomware on 21 Feb 2024.
Twitter	Hours	From the phone calls to the first scam tweets, the same day, 15 July 2020.
Twitch	Not published	Twitch has not said when the outside access began.

A short prevention list that matches these cases

- **Put a second step on every remote door.** A password alone should never open a remote portal or an admin tool. Prefer security keys for staff with powerful tools (Change Healthcare, Twitter).
- **Know your suppliers' suppliers.** Assume the partner's partner is a target too, and ask what they run (C-Edge).
- **Call back on a number you already have.** One habit that blunts most phone pretexts (Twitter).
- **Review every configuration change.** Scan for servers and storage that are open to the internet (Twitch, C-Edge).
- **Store passwords with slow, salted hashes and hold less personal data.** Old data nobody needs is pure risk (BigBasket).
- **Watch the exits.** Bulk data leaving a database or server should ring a bell with a named owner (BigBasket, Twitch, Change Healthcare).
- **Rehearse the bad day.** Test cut-offs, restores, offline fallbacks and public notices before you need them (C-Edge, Change Healthcare).

Sources used for dates and figures include: Cyble's November 2020 report on BigBasket and the press coverage that followed; NPCI's 31 July 2024 statement, CloudSEK's analysis and press reports on C-Edge Technologies; UnitedHealth Group's May 2024 testimony to the US Congress, its SEC filings and Change Healthcare's notices to the US Department of Health and Human Services; Twitter's July 2020 updates, the New York Department of Financial Services report of October 2020 and US Justice Department and Florida prosecutors' releases; and Twitch's statements of 6 and 15 October 2021. Clippings in this file are illustrations, not those sources.